Eli Romulo

Cibersegurança

Ele/Dele

Sou estudante da UniasSelvi em dois cursos: Segurança Cibernética (Cybersecurity) e Análise e Desenvolvimento de Sistemas. Este relatório é uma tarefa do curso de cybersecurity da Google.

Relatório de Avaliação de Controles e Conformidade

Avaliação Estratégica de Segurança Cibernética e Conformidade

- **Empresa Avaliada:** Bottom Toys
- **Analista de Segurança:** Eli Romulo de Araujo Martins
- **Data da Análise:** Agosto de 2024
- **Fonte:** Documento de Auditoria BOTTOM-TOYS-2024-AUDIT-V1

Parte 1: Checklist de Avaliação de Controles

A Bottom Toys possui atualmente este controle implementado?

Sim	Não	Controle	Explicação da Avaliação
[ ]	**[x]**	**Princípio do Menor Privilégio (Least Privilege)**	Atualmente, todos os funcionários têm acesso a dados sensíveis de clientes e registros financeiros. Os privilégios precisam ser restritos para reduzir o risco de violação de dados.
[ ]	**[x]**	**Planos de Recuperação de Desastres**	Não existem planos formais de recuperação de desastres ou de continuidade dos negócios. Estes precisam ser criados para garantir a resiliência operacional.
[ ]	**[x]**	**Políticas de Senhas**	Não há requisitos mínimos para senhas ou um sistema de gerenciamento centralizado, permitindo que agentes mal-intencionados acessem dados seguros com mais facilidade.
[ ]	**[x]**	**Separação de Funções (Separation of Duties)**	Indivíduos únicos podem autorizar e executar transações financeiras, o que representa um risco significativo de fraude interna e erro.

[ ]	**[x]**	**Criptografia**	Dados sensíveis não são criptografados em repouso ou em trânsito. A implementação da criptografia é essencial para garantir a confidencialidade das informações.
[ ]	**[x]**	**Sistema de Detecção de Intrusão (IDS)**	A empresa não possui um IDS para monitorar o tráfego de rede em busca de atividades suspeitas, o que a deixa cega para possíveis ataques em andamento.
[ ]	**[x]**	**Backups**	Não existem procedimentos regulares de backup para dados críticos do negócio. É necessário implementar uma rotina de backups para garantir a continuidade em caso de perda de dados.
[x]	[ ]	**Software Antivírus**	O software antivírus está instalado em todas as estações de trabalho e é atualizado regularmente, fornecendo uma camada de proteção básica contra malware.
[ ]	**[x]**	**Monitoramento de**	Sistemas legados

		Sistemas Legados	não são monitorados adequadamente, o que pode expor a empresa a vulnerabilidades conhecidas e não corrigidas.
[ ]	**[x]**	**Autenticação Multifator (MFA)**	A MFA não está implementada para o acesso a sistemas críticos, perdendo uma camada vital de segurança para prevenir o acesso não autorizado.
[ ]	**[x]**	**Gerenciamento de Vulnerabilidades**	Não há um processo regular de varredura de vulnerabilidades ou de gerenciamento de patches, deixando os sistemas suscetíveis a ataques que exploram falhas conhecidas.
[x]	[ ]	**Configuração de Firewall**	Um firewall básico está instalado. No entanto, ele não está configurado adequadamente com regras de segurança, limitando sua eficácia.
[x]	[ ]	**Vigilância por CFTV**	Câmeras de segurança monitoram os pontos de acesso físico, fornecendo um controle de segurança física adequado.

[x]	[ ]	**Detecção/Prevenção de Incêndio**	Sistemas de supressão de incêndio estão instalados nas salas dos servidores, protegendo os ativos físicos de TI.
[x]	[ ]	**Fechaduras (Acesso Físico)**	Fechaduras físicas protegem as salas dos servidores e outras áreas sensíveis, controlando o acesso físico aos ativos.

Parte 2: Checklist de Conformidade

A Bottom Toys adere atualmente a esta boa prática de conformidade?

Payment Card Industry Data Security Standard (PCI DSS)

Sim	Não	Boa Prática	Explicação da Avaliação
[ ]	**[x]**	**Apenas usuários autorizados acessam dados de cartão de crédito.**	Atualmente, todos os funcionários têm acesso aos dados internos da empresa, incluindo informações de cartão de crédito, violando o princípio do acesso restrito.
[ ]	**[x]**	**O armazenamento e a transmissão de dados de cartão de crédito são seguros.**	Os dados não são criptografados e o acesso é irrestrito, falhando em proteger as informações de pagamento dos clientes em todas as etapas.
[ ]	**[x]**	**Implementar criptografia para transações.**	A criptografia não é utilizada para dados financeiros, o que deixa as transações vulneráveis à interceptação e ao roubo de dados.
[ ]	**[x]**	**Adotar políticas seguras de gerenciamento de senhas.**	Não existe um sistema de gerenciamento de senhas ou políticas de complexidade, o que enfraquece a segurança das contas que acessam dados de pagamento.

General Data Protection Regulation (GDPR)

Sim	Não	Boa Prática	Explicação da Avaliação
[ ]	**[x]**	**A privacidade e a segurança dos dados de clientes da UE são garantidas.**	Os dados não são criptografados e o acesso não é restrito, o que viola os requisitos fundamentais de proteção de dados do GDPR.
[ ]	**[x]**	**Notificar clientes da UE sobre uma violação em até 72 horas.**	Não existe um plano formal de notificação de violação, o que impossibilita o cumprimento do prazo mandatório de 72 horas do GDPR.
[ ]	**[x]**	**Classificação e inventário adequados dos dados.**	Os ativos de TI são inventariados, mas os dados que eles contêm não são classificados, impedindo a aplicação de controles de segurança baseados na sensibilidade da informação.
[ ]	**[x]**	**Políticas e procedimentos de privacidade são aplicados.**	As políticas de privacidade existem, mas não são aplicadas de forma consistente, tornando-as ineficazes na prática.

System and Organization Controls (SOC 2)

Sim	Não	Boa Prática	Explicação da Avaliação
[ ]	**[x]**	**Políticas de acesso de usuário são estabelecidas.**	A ausência do Princípio do Menor Privilégio e da Separação de Funções demonstra uma falha em estabelecer e aplicar políticas de acesso adequadas.
[ ]	**[x]**	**Garantir a confidencialidade de dados sensíveis (PII/SPII).**	A criptografia não é utilizada, o que falha em proteger a confidencialidade de Informações de Identificação Pessoal (PII) e Informações Pessoais Sensíveis (SPII).
[x]	[ ]	**Manter a integridade dos dados.**	Medidas para garantir a integridade dos dados (consistência e precisão) estão em vigor, sendo um dos poucos controles funcionais.
[ ]	**[x]**	**Restringir o acesso a dados a pessoal autorizado.**	Todos os funcionários têm acesso a dados sensíveis, o que viola diretamente o princípio de acesso restrito a pessoal autorizado.

Parte 3: Recomendações Estratégicas

Para: Gestão de TI e Stakeholders da Bottom Toys

De: Eli Romulo de Araujo Martins, Analista de Segurança

Assunto: Ações Prioritárias para Mitigação de Riscos e Melhoria da Postura de Segurança

Com base na análise de controles e conformidade, é evidente que múltiplos pontos críticos precisam ser endereçados para proteger os ativos da Bottom Toys e garantir a continuidade dos negócios. As seguintes recomendações são propostas para mitigar os riscos identificados e alinhar a empresa com as melhores práticas de segurança e as regulamentações mandatórias.

1. Implementação de Controles de Segurança Fundamentais:

Múltiplos controles essenciais precisam ser implementados para fortalecer a postura de segurança da Bottom Toys e garantir a confidencialidade e a integridade de suas informações sensíveis. As ações prioritárias incluem:

- **Princípio do Menor Privilégio (Least Privilege) e Separação de Funções:** Redesenhar as permissões de acesso para garantir que os funcionários acessem apenas os dados estritamente necessários para suas funções. Isso reduz drasticamente a superfície de ataque interna e o risco de fraude.
- **Criptografia:** Implementar criptografia forte (e.g., AES-256) para todos os dados sensíveis em repouso (armazenados) e em trânsito (na rede). Esta é uma medida não negociável para proteger dados de clientes e financeiros.
- **Plano de Recuperação de Desastres (DRP) e Backups:** Desenvolver e testar um DRP formal e estabelecer uma rotina de backups automáticos e regulares (seguindo a regra 3-2-1). Isso garante que a empresa possa se recuperar de um incidente cibernético ou falha de sistema com o mínimo de impacto.
- **Sistema de Detecção de Intrusão (IDS) e Gerenciamento de Vulnerabilidades:** Implementar um IDS para monitoramento proativo da rede e estabelecer um processo contínuo de varredura e correção de vulnerabilidades para proteger contra ameaças conhecidas.
- **Políticas de Senhas e Autenticação Multifator (MFA):** Forçar o uso de senhas complexas e implementar a MFA para todos os acessos a sistemas críticos. Isso adiciona uma camada de segurança crucial contra o comprometimento de credenciais.

2. Ações para Conformidade Regulatória:

Para corrigir as lacunas de conformidade com **PCI DSS, GDPR e SOC 2**, a Bottom Toys deve focar em:

- **Implementar os controles técnicos mencionados acima:** A criptografia, o controle de acesso (Least Privilege) e a separação de funções são requisitos fundamentais para todas essas regulamentações.
- **Classificar os Dados:** Realizar uma classificação formal dos dados para identificar onde residem as informações mais sensíveis (dados de cartão de crédito, PII de clientes da UE). Isso permitirá a aplicação de controles mais rigorosos onde for mais necessário.

- **Desenvolver um Plano de Resposta a Incidentes:** Criar um plano claro que inclua procedimentos para a notificação de violações de dados, cumprindo o requisito de 72 horas do GDPR.

A implementação dessas recomendações não deve ser vista como um projeto pontual, mas como o início de um programa de segurança cibernética contínuo e estratégico, essencial para o sucesso e a sustentabilidade da Bottom Toys.

3 CARACTERÍSTICAS SOBRE MIM:

📞 Entre em contato!

Eli Romulo de Araujo Martins

📧 Email: eliromulo@gmail.com

🔗www.linkedin.com/in/eli-martins-5911b82a0

GitShiryu: (CodeDragon)

Relatório confidencial - Elaborado para fins acadêmicos - 2025